

Session 10 – Role-Based Authorization (ADMIN vs CUSTOMER)

1. Objective

Xây dựng hệ thống phân quyền (**Role-Based Authorization - RBAC**) cho ShopHub với hai vai trò:

- **ADMIN:** Quản lý sản phẩm, tạo, xóa sản phẩm và truy cập trang quản trị.
- **CUSTOMER:** Chỉ xem sản phẩm, đặt hàng và không được phép quản lý sản phẩm.

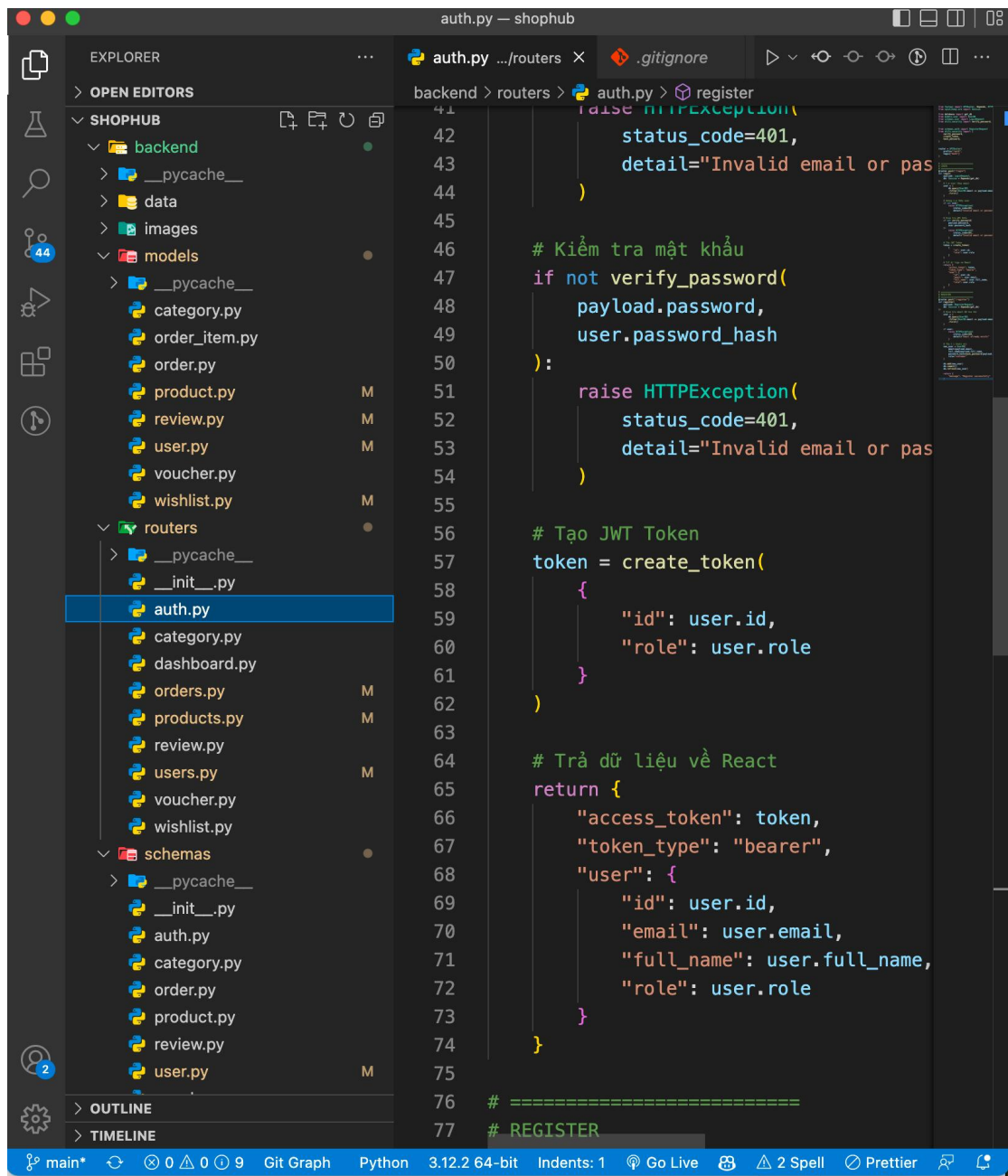
2. Backend

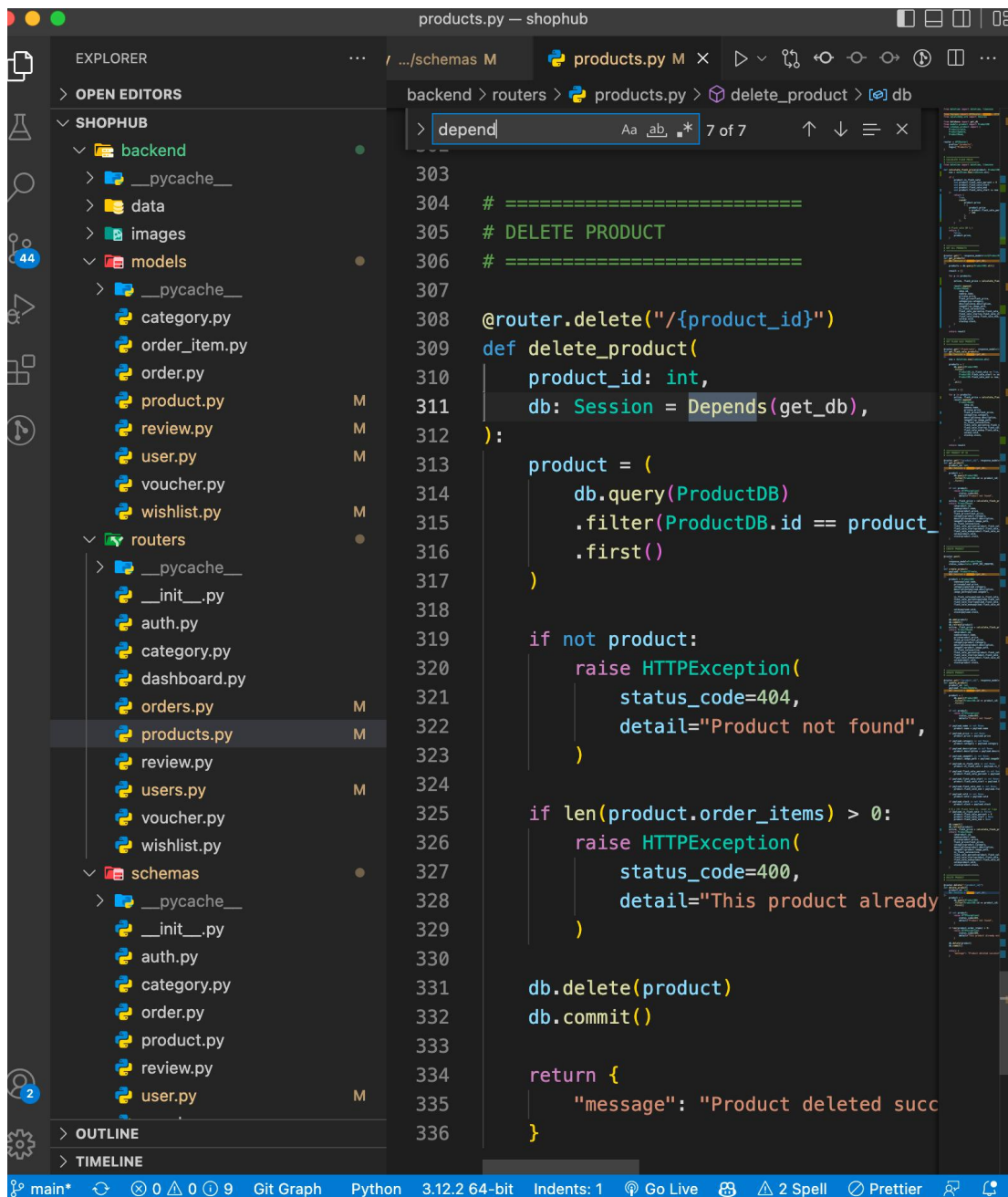
Nội dung

- Thêm **role** vào JWT khi đăng nhập.
- Tạo `get_current_user()` để xác thực người dùng từ token.
- Tạo `require_admin()` để kiểm tra quyền ADMIN.
- Áp dụng `require_admin()` vào:
 - `POST /products`
 - `DELETE /products/{id}`

Nếu:

- Không có token → **401 Unauthorized**
- Không phải ADMIN → **403 Forbidden**





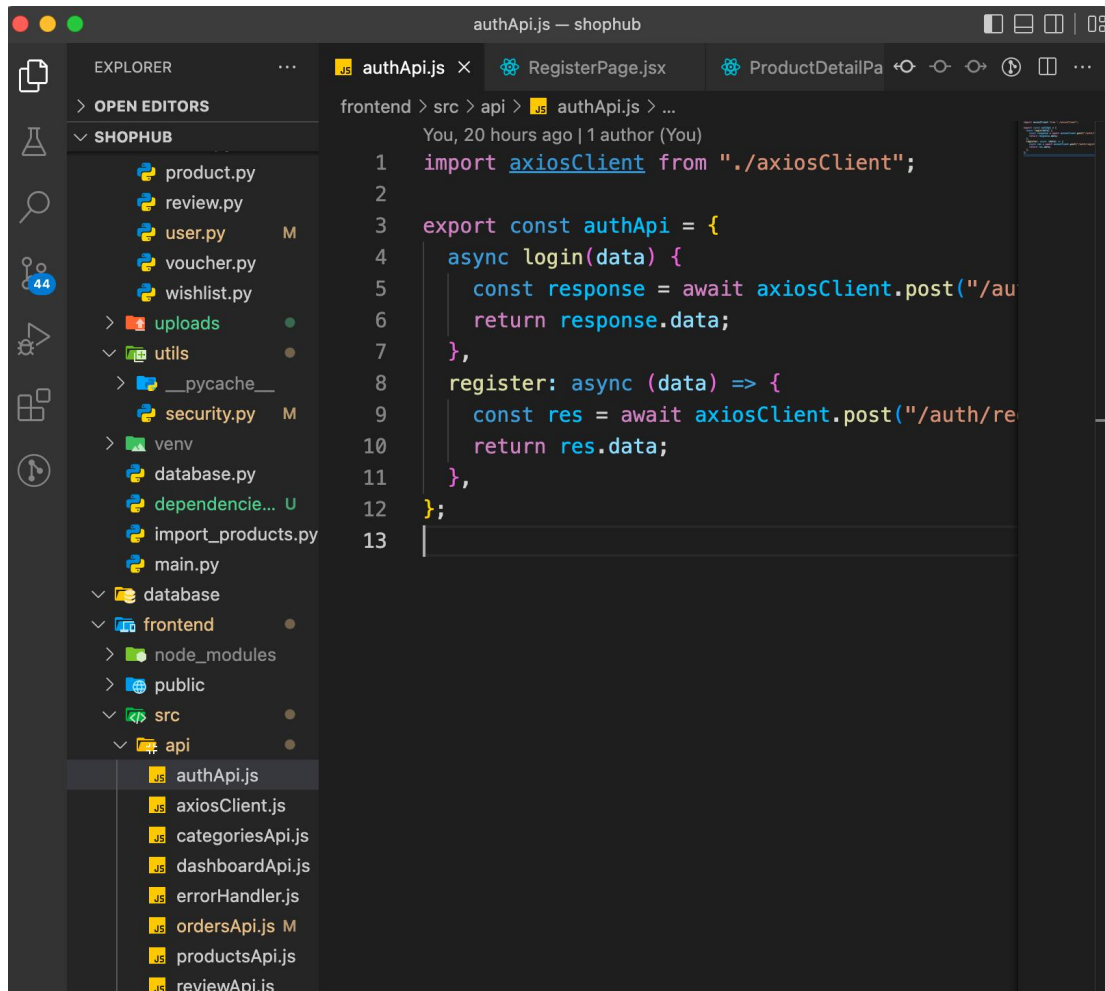
3. Frontend

Nội dung

Sau khi đăng nhập:

- Lưu token.
- Lưu thông tin user và role vào localStorage.
- Sử dụng useAuth() để lấy role.

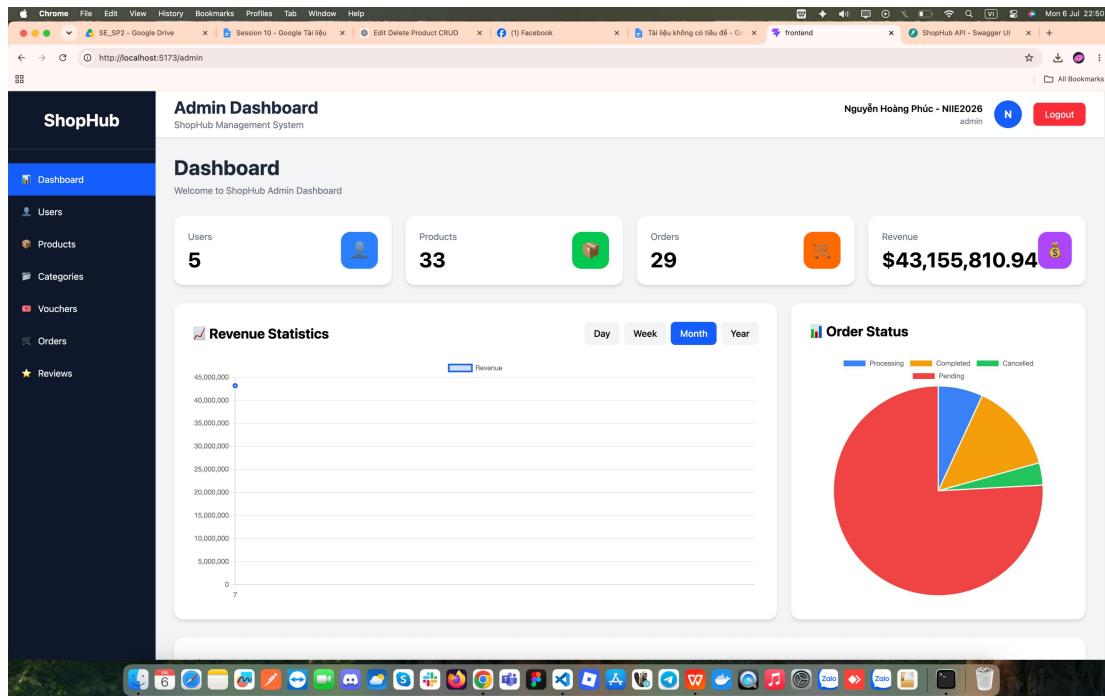
- Tạo AdminRoute để bảo vệ trang Admin.
- Ấn nút Create Product và Delete nếu là CUSTOMER.



4. Kết quả

ADMIN

- Đăng nhập thành công.
- Truy cập Dashboard.
- Tạo sản phẩm.
- Xóa sản phẩm.



CUSTOMER

- Đăng nhập thành công.
- Chỉ xem sản phẩm.
- Không thấy nút Create Product.
- Không thấy nút Delete.
- Không truy cập được Admin.

